

A decorative frame composed of two thick, light-colored L-shaped lines. One L-shape is positioned in the top-left corner, and the other is in the bottom-right corner, creating an open rectangular frame around the central text.

LDAP-ИНЪЕКЦИИ

Введение

LDAP означает Lightweight Directory Access Protocol. Это сетевой протокол прикладного уровня для доступа к так называемой службе каталогов. Протокол является не текстовым (как, например, HTTP), а бинарным. LDAP протокол обычно используется поверх TCP/IP, но лучше еще использовать в рамках TLS соединения.

Введение

Если вкратце, то LDAP сервер содержит базу данных, где данные хранятся в виде “атрибут = значение”. LDAP описывает как эти данные могут быть получены и изменены.

На текущий момент известно некоторое количество ПО, которое поддерживает LDAP, например:

- ☐ OpenLDAP
- ☐ Java содержит в себе LDAP-клиент, который доступен через JNDI.

Что такое LDAP-инъекция?

LDP-инъекция (LDAP injection) это способ нападения, который позволяет злобному злоумышленнику коварно модифицировать LDAP-запрос, который использует приложение для обращения к LDAP-хранилищу. Достигается это злодейство путем отправки приложению хитроумно подготовленных данных, которые содержат части LDAP-запроса. В результате беспринципный злоумышленник может отправлять LDAP-хранилищу всевозможные запросы, порой даже абсолютно любые, которые приложение само никогда бы не отправило. Это в свою очередь может привести к несанкционированному чтению или даже изменению всякой важной информации, которая может храниться в LDAP-хранилище. Обычно LDAP-инъекции возникают, потому что приложение не проверяет входные данные от пользователя, который может оказаться злобным злоумышленником, и наивно использует их для построения LDAP-запроса к базе данных.

Пример LDAP-инъекции

Представим, что у нас есть LDAP-сервер, который надежно спрятан в нашей внутренней сети, которую защищает от внешнего мира наша стена, которая больше известна, как firewall. Пусть этот LDAP-сервер хранит данные пользователей, такие как адреса, пароли, явки. Еще представим, что у нас есть некое приложение, которое использует данные из нашего LDAP-хранилища для аутентификации пользователей. Другими словами, для предоставления доступа наше приложение просит пользователя ввести имя и пароль, которые оно потом сверяет с данными, которые хранятся на нашем LDAP-сервере.

Пример LDAP-инъекции

Наше приложение спрашивает у пользователя его имя и пароль, которые пользователь предоставляет через параметры командной строки. Далее наше приложение отправляет LDAP-запрос к нашему LDAP-хранилищу, чтобы получить соответствующую запись о нашем пользователе. Если такая запись была найдена, то счастливый пользователь получает доступ, который ознаменовывается появлением сообщения “Access granted”.

Пример LDAP-инъекции

Проблема этого простого приложения заключается в том, что оно подставляет имя и пароль, которые предоставляет ему пользователь, прямо в LDAP-запрос. Такое халатное поведение приложения дает хитрому злоумышленнику возможность модифицировать запрос, который отправляется к LDAP-хранилищу. В свою очередь это может быть использовано, например, для обхода аутентификации. Если злоумышленник не знает пароля Боба, то он может попросту использовать строку `bob)(|(uid=bob` в качестве имени пользователя и строку `wrong)` в качестве пароля, что в результате позволит ему получить долгожданный доступ.

Пример LDAP-инъекции

Можно видеть, что приложение отправило запрос `(&(uid=bob)(|(uid=bob)(userPassword=wrong)))` к LDAP-хранилищу. LDAP использует в запросах к базе данных так называемую “польскую нотацию”. Этот запрос означает “`(uid == bob) and (uid=bob or userPassword=wrong)`”. Это логическое выражение всегда истинно для записи Боба, поэтому запрос всегда возвращает запись Боба, если даже был подsunут неправильный пароль. В результате злобный злоумышленник может обойти аутентификацию.

Пример LDAP-инъекции

Настоящее использование LDAP-инъекции может зависеть от разных вещей, например:

- ☐ LDAP-запроса, который используется приложением
- ☐ Версии LDAP-сервера
- ☐ Логике работы приложения

Пример LDAP-инъекции

В природе можно наблюдать три основных разновидностей LDAP-запросов:

- **Запрос без логических операторов.** Выглядят они как (field=value). Если даже мы можем поместить что угодно вместо `value`, то мы все равно не сможем использовать никакие логические операторы, потому что записи в Польской нотации требуют, чтобы логический оператор был вначале. Все что можно сделать, это попробовать использовать какую-то уязвимость в самом LDAP-сервере, если она может быть вызвана каким-то значением value. Например, это может быть переполнение буфера, если конечно сервер ему подвержен.

- **Оператор AND находится вначале поискового запроса.** Выглядит это как (&(field1=value1)(field2=value2)). Пример подобной ситуации был рассмотрен выше.

- **Оператор OR находится вначале поискового запроса.** Выглядит это как (|(field1=value1)(field2=value2)).

Пример LDAP-инъекции

Для успеха предприятия очень хорошо и полезно знать, какой тип запроса используется приложением.

Приложение также может использовать LDAP-запросы для обновления данных в LDAP-хранилище. LDAP использует LDAP Data Interchange Format (LDIF) для обновления данных в хранилище. LDIF представляет собой список команд для добавления, удаления или изменения записей в базе данных. Это попросту набор записей, одна запись – одна команда.

Пример LDAP-инъекции

Версия LDAP-сервера тоже может иметь значение, потому что разные версии LDAP-серверов могут иметь разные особенности в обработке запросов. Иногда коварный злоумышленник может использовать LDAP-инъекцию таким образом, что LDAP-запрос включает в себя несколько поисковых запросов. Если LDAP-сервер использует только первый запрос и игнорирует остальные, вместо возвращения ошибки, то это может помочь в осуществлении атаки. К сожалению, синтаксис LDAP-запросов не допускает комментирования окончания запроса, как это можно сделать в SQL.

LDAP-инъекции вслепую (Blind LDAP injections)

Blind LDAP-инъекции чем-то похожи на blind SQL-инъекции. Приложение может быть уязвимо к LDAP-инъекции, но может так случиться, что вредное приложение не будет отображать все поля записей. Такое печальное обстоятельство не позволит злобному злоумышленнику просто прочесть содержимое LDAP-хранилища. Но **если приложение каким-то образом дает знать, что отправленный запрос с данными от злоумышленника завершился успешно или нет, то такое поведение может позволить хитрому злоумышленнику задавать серверу так называемые да/нет вопросы.** В результате беспринципный злоумышленник может осуществить эффективный перебор и извлечь ценные данные из базы данных.

LDAP-инъекции вслепую (Blind LDAP injections)

Представим, что у нас есть такое приложение на Java. Оно спрашивает у пользователя его идентификатор для поиска записи пользователя в базе данных. Если запись была найдена, то приложение печатает номер телефона пользователя. Если не найдена, то приложение просто сообщает, что ничего не было найдено.

LDAP-инъекции вслепую (Blind LDAP injections)

```
$ javac -d classes LDAPInfo.java
```

```
$ java -cp classes LDAPInfo bob
```

```
LDAP query: (&(uid=bob)(objectClass=person))
```

```
Phone: telephoneNumber: 555-9999
```

```
$ java -cp classes LDAPInfo boba
```

```
LDAP query: (&(uid=boba)(objectClass=person))
```

```
Nobody found!
```

LDAP-инъекции вслепую (Blind LDAP injections)

Кто-то может заметить, что LDAPInfo подвержен LDAP-инъекции. Хотя приложение лишь печатает номер телефона, коварный злоумышленник все равно может извлечь ценные данные из других полей. Например, злобный злоумышленник может спросить у сервера, начинается ли поле userPassword в записи Боба с буквы 'а'.

LDAP-инъекции вслепую (Blind LDAP injections)

Если передать строку `bob)(userPassword=a*` в качестве имени пользователя, то это приведет к появлению сообщения `'Nobody found!'`. Приложение построило запрос `(&(uid=bob)(userPassword=a*)(objectClass=person))` , который ничего не вернул, потому что поле `userPassword` из записи Боба не начинается с буквы `'a'`. Теперь коварный злоумышленник может перебрать первую букву пароля Боба.

LDAP-инъекции вслепую (Blind LDAP injections)

Как только злобный злоумышленник попробует букву 's', то приложение вернет номер телефона Боба. Это означает, что пароль Боба начинается с буквы 's'. Дальше хитрый злоумышленник начинает перебирать вторую букву пароля Боба подставляя строки вида `bob)(userPassword=sa*`, `bob)(userPassword=sb*`, `"bob)(userPassword=sc*` и так далее. Это позволяет реализовать эффективный перебор, чтобы получить пароль Боба.

Как предотвратить LDAP-инъекции

Приложениям следует экранировать все специальные символы в данных, которые приходят от пользователей.

Дополнительно мерой может быть отключение индексирования полей, которые могут содержать важную информацию такую как пароли.